

NARRATIVA EXPLICATIVA DEL KIT DE ENCUESTA

Por qué esta encuesta, por qué ahora y por qué así

Contexto, Propósito y Uso de los Resultados • CVSS 4.0 en España 2025–2026

"Investigar es la forma más honesta de admitir que no se sabe. Y la más productiva de empezar a saber."

1. EL PROBLEMA QUE ESTA ENCUESTA QUIERE MEDIR

1.1 El Estándar Más Usado y Peor Aplicado del Mundo

El CVSS es el sistema de puntuación de vulnerabilidades más utilizado del planeta. Aparece en los informes de INCIBE, en los boletines del CCN-CERT, en las alertas de todos los fabricantes de software y en la mayoría de las herramientas de gestión de vulnerabilidades. Es, en todos los sentidos, el idioma común de la ciberseguridad técnica.

Y, sin embargo, hay un secreto mal guardado en el sector: la mayoría de las organizaciones lo usan de forma incompleta, cuando no incorrecta. El número que aparece en el boletín del proveedor —ese "9.8 Crítico" que genera alarma en los equipos de seguridad— es solo la puntuación Base, el peor escenario técnico imaginado por quien describió la vulnerabilidad. No incorpora si existe exploit activo, no considera si la organización tiene controles que mitigan el riesgo, no evalúa si el sistema afectado es una joya de la corona o un servidor de pruebas desconectado.

CVSS 4.0, publicado en noviembre de 2023, ofrece las herramientas para hacerlo bien: métricas Threat para incorporar inteligencia de amenazas, métricas Environmental para contextualizar al entorno específico, métricas Supplemental para señalar dimensiones como la seguridad física o la automatizabilidad del ataque. Pero la evidencia disponible sugiere que solo el 2,4% de los CVEs tienen puntuación v4 asignada y que las métricas contextuales (Threat, Environmental, Supplemental) rara vez se calculan en la práctica.

Esta encuesta existe para **medir esa brecha con rigor científico** en el contexto español.

1.2 El Momento: 2025–2026

El año 2025 marcó un punto de inflexión en la ciberseguridad española y europea:

- INCIBE gestionó 122.223 ciberincidentes (+26% interanual) y detectó 237.028 sistemas vulnerables en España.
- El CCN-CERT reportó 278 incidentes críticos (+293%), con 128 casos de ciberespionaje.
- Los hospitales españoles soportaron más de 2.400 ciberataques semanales.
- La EUVD (European Union Vulnerability Database) fue lanzada por ENISA en abril de 2025, estableciendo soberanía europea sobre la gestión de vulnerabilidades.
- El Cyber Resilience Act entra en vigor en septiembre de 2026, creando obligaciones de notificación que transformarán el ecosistema de gestión de vulnerabilidades.

En este contexto, la pregunta no es ya si las organizaciones españolas necesitan mejorar su gestión de vulnerabilidades. La pregunta es **cuánto, dónde y en qué dimensión concreta** necesitan mejorar. Esta encuesta proporciona el diagnóstico necesario para responderla.

2. ARQUITECTURA CONCEPTUAL DE LA ENCUESTA

2.1 El Modelo de Madurez Subyacente

El instrumento está diseñado para evaluar cinco dimensiones de madurez en la gestión de vulnerabilidades con CVSS, correspondientes a los cinco grupos de secciones:

MODELO DE MADUREZ CVSS 4.0		
[D1]	Conocimiento	→ ¿Saben qué es CVSS 4.0?
[D2]	Métricas Base	→ ¿Usan correctamente el B?
[D3]	Métricas Threat	→ ¿Enriquecen con inteligencia?
[D4]	Métricas Env.	→ ¿Contextualizan al entorno?
[D5]	Métricas Suppl.	→ ¿Incorporan Safety/Recovery?
[D6]	Integración norm.	→ ¿Alinean con ENS/NIS2/DORA?
[D7]	Infraestructura	→ ¿Tienen las herramientas?
[D8]	Gobierno/Cultura	→ ¿Lo gestionan como proceso?

El **Índice de Madurez Global (IGM)** es la media ponderada de las puntuaciones en cada dimensión, calculado en la Plantilla Excel (documento e).

2.2 Las Preguntas Irresistibles

El diseño del cuestionario parte de un conjunto de hipótesis de investigación que las respuestas deben ayudar a confirmar o refutar:

H1: La mayoría de organizaciones del sector público español utilizan exclusivamente el CVSS Base Score sin enriquecimiento contextual.

H2: El tamaño organizacional es el predictor más fuerte del nivel de madurez CVSS: las grandes administraciones tienen mayor madurez que los pequeños ayuntamientos.

H3: La obligatoriedad ENS no garantiza per se una gestión de vulnerabilidades CVSS madura; la brecha entre cumplimiento formal y madurez operacional es significativa.

H4: La integración de la EUVD (ENISA, 2025) es aún marginal en las organizaciones españolas, con predominio de NVD e INCIBE como fuentes primarias.

H5: Menos del 20% de las organizaciones encuestadas utilizan métricas Threat de forma sistemática para ajustar la priorización de vulnerabilidades.

H6: La brecha de herramientas (herramientas que no soportan CVSS 4.0) es el principal obstáculo tecnológico para la adopción, mientras que la brecha de cultura (resistencia al parcheo) es el principal obstáculo organizacional.

3. GUÍA DE LECTURA: LO QUE CADA SECCIÓN BUSCA

Sección 1 — Perfil Organizacional

No es burocracia; es el mapa del territorio. Permite segmentar los resultados por tipo de administración, tamaño, sector y CCAA. Sin estas variables, los datos son una foto global sin geografía. Con ellas, aparecen los patrones: qué hace diferente la CCAA con mayor madurez, por qué ciertos sectores van sistemáticamente por delante, qué explica la brecha entre municipios.

Sección 2 — Conocimiento y Adopción

El problema comienza por el nombre. Antes de evaluar si alguien aplica bien CVSS 4.0, hay que saber si sabe que existe. Los datos globales indican que dos años después de su publicación, la adopción es marginal. En España, donde INCIBE ya lo usa como referencia en sus alertas, la situación puede ser diferente —o puede no serlo. Esta sección lo mide.

Secciones 3–6 — Las Cuatro Familias de Métricas

El corazón del instrumento. Cada sección evalúa una dimensión del uso de CVSS: las métricas Base (¿se cuestionan las puntuaciones del proveedor?), Threat (¿se incorpora inteligencia de amenazas?), Environmental (¿se contextualiza al entorno?) y Supplemental (¿se consideran Safety y Automatability?). La progresión de las secciones sigue la lógica del ciclo de vida CVSS: B – BT – BTE, con las métricas Supplemental como capa adicional de contexto.

Sección 7 — Marco Normativo

La regulación como acelerador y como obstáculo. NIS2, DORA y CRA están redibujando el paisaje regulatorio europeo. El ENS sigue siendo el marco de referencia para el sector público español. Esta sección evalúa si las organizaciones han integrado CVSS en su arquitectura de cumplimiento o si lo tratan como una herramienta técnica desconectada del marco normativo.

Sección 8 — Infraestructura Tecnológica

Las herramientas importan más de lo que los metodólogos admiten. Una metodología perfecta aplicada con hojas de cálculo es, en la práctica, inviable a escala. Esta sección diagnostica el estado del parque tecnológico de gestión de vulnerabilidades: ¿soportan CVSS 4.0?, ¿están integradas con threat intelligence?, ¿existe cobertura real del inventario?

Sección 9 — Gobierno y Cultura

El factor humano es siempre el factor decisivo. La mejor infraestructura y la metodología más rigurosa fallan si el proceso de gestión no está gobernado, si los SLAs de remediación no existen o no se cumplen, si el equipo no tiene formación actualizada o si la dirección no recibe información útil y no toma decisiones basadas en ella.

Sección 10 — Perspectiva Estratégica

La encuesta como escenario de futuro. Esta sección invita a los participantes a salir del operacional diario y reflexionar sobre el horizonte: ¿qué debería evolucionar en CVSS?, ¿qué papel debe jugar la IA?,

¿cómo debería responder la administración pública española? Las respuestas abiertas de esta sección son el material cualitativo más rico del instrumento.

4. CÓMO USAR LOS RESULTADOS: GUÍA PARA DISTINTOS AUDIENCIAS

4.1 Para el Equipo de Seguridad (Uso Operacional)

Los resultados permiten:

- Identificar brechas específicas en el proceso CVSS propio mediante comparación con benchmarks sectoriales
- Priorizar inversiones de mejora: ¿la limitación es de herramientas, de datos de inteligencia o de proceso?
- Justificar solicitudes presupuestarias con evidencia comparativa ("el 73% de organizaciones equivalentes ya integran threat intelligence en sus puntuaciones CVSS")

4.2 Para la Dirección y el Consejo (Uso Ejecutivo)

Los resultados traducen el lenguaje técnico en lenguaje de riesgo organizacional:

- El IGM (Índice de Madurez Global) proporciona un número comparable y trazable en el tiempo
- Los benchmarks por sector y tamaño ofrecen contexto ("estamos por encima/debajo de la media del sector público")
- Las brechas de cumplimiento normativo (NIS2, ENS, CRA) señalan riesgos regulatorios concretos

4.3 Para las Administraciones Públicas (Uso Político y Regulatorio)

- CCN-CERT e INCIBE: identificar los segmentos del sector público con mayor brecha de madurez para focalizar programas de apoyo y capacitación
- CNPIC: evaluar el estado de los operadores de infraestructuras críticas en gestión de vulnerabilidades OT/ICS con CVSS 4.0
- Ministerio de Transformación Digital: fundamentar políticas públicas de ciberseguridad con evidencia territorial (por CCAA)

4.4 Para la Comunidad Investigadora (Uso Académico)

- Validación o refutación de las hipótesis planteadas (H1–H6)
- Datos para comparación longitudinal (réplica anual)
- Datos para estudios comparativos internacionales (UE, LATAM)
- Base empírica para modelos de predicción de brecha CVSS

5. EL TONO DE LA ENCUESTA: UNA NOTA SOBRE EL ESTILO

El instrumento ha sido diseñado deliberadamente con un tono que combina rigor metodológico con cierta ironía constructiva. No es accidental. La ciberseguridad sufre de un exceso de documentación solemne y un déficit de reflexión honesta sobre la brecha entre lo que se dice y lo que se hace.

Las preguntas abiertas invitan a esa honestidad. El tono irónico de algunas instrucciones ("Pensaba que la versión más reciente era la 3.1" como opción de respuesta legítima y sin juicio) busca reducir el sesgo de deseabilidad social: si el cuestionario acepta abiertamente que hay organizaciones que no conocen la

v4, es más probable que los que están en esa situación lo admitan en lugar de marcar una opción más "presentable".

El propósito no es juzgar, sino medir. Y medir bien requiere que las organizaciones con menor madurez se sientan cómodos respondiendo con honestidad tanto como las más avanzadas.

Kit de Encuesta CVSS 4.0 · España 2025–2026 · Narrativa Explicativa
Versión 1.0 · Abril 2026